360ADVANCED

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

SOC 2® Type 2 Report on Controls Relevant to Security, Availability, and Confidentiality for AI Services

Anthropic, Inc.

April 16, 2023 to September 30,2023

AICPA SOC
aicpa.org/soc4so
SOC for Service Organizations | Service Organizations

ANTHROPIC, INC.

Table of Contents

SECTION 1: INDEPENDENT SERVICE AUDITOR'S REPORT 1

SECTION 2: MANAGEMENT'S ASSERTION 6

SECTION 3: DESCRIPTION OF THE SYSTEM 8

SCOPE OF REPORT AND DISCLOSURES 9
- Overview 9
- Trust Services Categories and Related Criteria 9
- Scope 10
- Sub-Service Organizations 11
- Significant Changes during the Examination Period 11
- Subsequent Events 11
- System Incidents 11
- Using the Work of the Internal Audit Function 11

OVERVIEW OF OPERATIONS AND THE SYSTEM 12
- Company Overview and Background 12
- Overview of the AI Services system 12
- Principal Service Commitments and System Requirements 12

OVERVIEW OF RELEVANT INFRASTRUCTURE 14
- Infrastructure 14
- Software 14
- People 15
- Procedures 15
- Data 18

RELEVANT ASPECTS OF CONTROL ENVIRONMENT, RISK ASSESSMENT, INFORMATION AND COMMUNICATIONS SYSTEMS, AND MONITORING 19
- Control Environment 19
- Risk Assessment 21
- Information and Communication Systems 22
- Monitoring 23

CATEGORIES, CRITERIA, AND RELATED CONTROLS 24

COMPLEMENTARY CONTROL CONSIDERATIONS 25

SECTION 4: CATEGORIES, CRITERIA, CONTROL DESCRIPTIONS, RELATED CONTROLS AND TESTS OF OPERATING EFFECTIVENESS 26

INFORMATION PROVIDED BY THE SERVICE AUDITOR 27
- Introduction 27
- Tests of Operating Effectiveness 27
- Types of Tests Performed 28
- Procedures for Assessing Completeness and Accuracy of IPE 28
- Sampling Methodology 29

CATEGORIES, CRITERIA, AND RELATED CONTROLS 30
- Security (Common Criteria to All Categories) 30
- Availability Category and Criteria 84
- Confidentiality Category and Criteria 87

Downloaded at Fri, 11 Apr 2025 16:56:03 GMT
Downloaded by read@cloudcontrolstudio.com

SECTION 1:

INDEPENDENT SERVICE AUDITOR'S REPORT

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

INDEPENDENT SERVICE AUDITOR'S REPORT

To Anthropic, Inc.:

Scope

We have examined the accompanying description of Anthropic, Inc.'s ("Anthropic") AI Services system throughout the period April 16, 2023 to September 30, 2023, based on the criteria for a description of a service organization's system in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance — 2022)* (description criteria), and the suitability of the design and operating effectiveness of controls stated in the description throughout the period April 16, 2023 to September 30, 2023, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, and Confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus — 2022*) in AICPA*, Trust Services Criteria*.

Anthropic uses Google LLC, a sub-service organization, for cloud hosting services. The description indicates that complementary sub-service organization controls that are suitably designed and operating effectively are necessary, along with controls at Anthropic, to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria. The description presents Anthropic's controls, the applicable trust services criteria, and the types of complementary sub-service organization controls assumed in the design of Anthropic's controls. The description does not disclose the actual controls at the sub-service organization. Our examination did not include the services provided by the sub-service organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary sub-service organization controls.

Service Organization's Responsibilities

Anthropic's management is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved. Anthropic's management has provided the accompanying assertion titled "Management of Anthropic, Inc.'s Assertion" included in Section 2 of this report about the description and the suitability of design and operating effectiveness of controls stated therein. Management is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of the controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements

Downloaded at Fri, 11 Apr 2025 10:06:02 GMT
Downloaded by ccarl@chinapatrolstudio.com

- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusion about the suitability of the design or operating effectiveness of controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested, and the nature, timing, and results of those tests are presented in Section 4 of this report.

Controls That Were Not Tested During the Period

Anthropic's description of its AI Services system discusses its incident response procedures, which includes the controls implemented and operated to assess major incidents through root-cause analysis. However, during the period April 16, 2023 to September 30, 2023, Anthropic did not have any major incidents that would warrant the operation of the related controls.

Because the controls described above were not required to operate during the period, we did not test the operating effectiveness of those controls to evaluate the following trust services criteria:

- CC7.5 The entity identifies, develops, and implements activities to recover from identified security incidents.

Downloaded at Fri, 11 Apr 2026 15:56:03 GMT
Downloaded by asad@claritycontrolstudio.com

Anthropic's description of its AI Services system also discusses its vendor onboarding procedures, which includes the controls implemented and operated to execute service level agreements with managed service providers, execute agreements with vendors that access sensitive data that define responsibilities, execute non-disclosure agreements, execute business associate agreements, and perform due diligence activities as part of the vendor onboarding process. However, during the period April 16, 2023 to September 30, 2023, Anthropic did not onboard any vendors that would warrant the operation of the related controls.

Because the controls described above were not required to operate during the period, we did not test the operating effectiveness of those controls to evaluate the following trust services criteria:

- CC1.5 COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.
- CC2.3 COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.
- CC3.2 COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.
- CC9.2 The entity assesses and manages risks associated with vendors and business partners.
- C1.1 The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.

Anthropic's description of its AI Services system also discusses its asset destruction procedures, which includes the controls implemented and operated to securely destroy information assets and receive a destruction declaration upon completion. However, during the period April 16, 2023 to September 30, 2023, Anthropic did not dispose of any information assets that would warrant the operation of the related controls.

Because the controls described above were not required to operate during the period, we did not test the operating effectiveness of those controls to evaluate the following trust services criteria:

- CC6.5 The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.
- C1.2 The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

Opinion

In our opinion, in all material respects:

a. the description presents Anthropic's AI Services system that was designed and implemented throughout the period April 16, 2023 to September 30, 2023, in accordance with the description criteria;

b. the controls stated in the description were suitably designed throughout the period April 16, 2023 to September 30, 2023, to provide reasonable assurance that Anthropic's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the sub-service organization and user entities applied the complementary controls, if applicable, assumed in the design of Anthropic's controls throughout that period; and

c. the controls stated in the description operated effectively throughout the period April 16, 2023 to September 30, 2023, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary sub-service organization and complementary user entity controls, if applicable, assumed in the design of Anthropic's controls operated effectively throughout that period.

Downloaded by asaad@cloudcontrolstudio.com Downloaded on Fri, 11 Apr 2025 15:56:03 GMT

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of Anthropic, user entities of Anthropic's AI Services system during some or all of the period April 16, 2023 to September 30, 2023, business partners of Anthropic subject to risks arising from interactions with the AI Services system, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, the sub-service organization, and other parties
- Internal control and its limitations
- If applicable, complementary user entity controls and complementary sub-service organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

February19, 2024
St. Petersburg, Florida

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

SECTION 2:

MANAGEMENT'S ASSERTION

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

MANAGEMENT OF ANTHROPIC INC.'S ASSERTION

February19, 2024

We have prepared the accompanying description of Anthropic, Inc.'s ("Anthropic") AI Services system throughout the period April 16, 2023 to September 30, 2023, based on the criteria for a description of a service organization's system in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (With Revised Implementation Guidance — 2022)* in AICPA, *Description Criteria* (description criteria). The description is intended to provide report users with information about the AI Services system that may be useful when assessing the risks arising from interactions with Anthropic's system, particularly information about system controls that Anthropic has designed, implemented, and operated to provide reasonable assurance that our service commitments and system requirements were achieved based on the trust services criteria relevant to Security, Availability, and Confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (With Revised Points of Focus — 2022)* in AICPA, *Trust Services Criteria*.

Anthropic uses Google LLC, a sub-service organization, for cloud hosting services. The description indicates that complementary sub-service organization controls that are suitably designed and operating effectively are necessary, along with controls at Anthropic, to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria. The description presents Anthropic's controls, the applicable trust services criteria, and the types of complementary sub-service organization controls assumed in the design of Anthropic's controls. The description does not disclose the actual controls at the sub-service organization.

We confirm, to the best of our knowledge and belief, that

a. the description presents Anthropic's AI Services system that was designed and implemented throughout the period April 16, 2023 to September 30, 2023, in accordance with the description criteria.

b. the controls stated in the description were suitably designed throughout the period April 16, 2023 to September 30, 2023, to provide reasonable assurance that Anthropic's service commitments and system requirements would be achieved based on the applicable trust services criteria, if our controls operated effectively throughout the period, and if the sub-service organization and user entities applied the complementary controls, if applicable, assumed in the design of Anthropic's controls throughout that period.

c. the controls stated in the description operated effectively throughout the period April 16, 2023 to September 30, 2023, to provide reasonable assurance that Anthropic's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary sub-service organization controls and complementary user entity controls, if applicable, assumed in the design of Anthropic's controls operated effectively throughout that period.

d. our description of the AI Services system discusses Anthropic's incident response procedures, which includes the controls around assessing major incidents through root-cause analysis, its vendor onboarding procedures, which includes the controls to execute service level agreements with managed service providers, execute agreements that define responsibilities with vendors that access sensitive data, execute non-disclosure agreements, execute business associate agreements, and perform due diligence activities as part of the vendor onboarding process, and its asset destruction procedures, which includes the controls to securely destroy information assets and receive a destruction declaration upon completion. However, during the period April 16, 2023 to September 30, 2023, Anthropic did not have any major incidents, onboard any vendors, or dispose of any information assets that would warrant the operation of related controls.

/s/ Anthropic, Inc.

Jason Clinton – Chief Information Security Officer

Siah Burke – HIPAA Security Officer

Downloaded by saad@cloudcontrolaudit.com at Fri, 11 Apr 2025 10:56:00 GMT

SECTION 3:

DESCRIPTION OF THE SYSTEM

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

SCOPE OF REPORT AND DISCLOSURES

Overview

This description of the system of controls provided by Anthropic, Inc.'s ("Anthropic") management, as related to Statement on Standards for Attestation Engagements No. 21 '*Direct Examination Engagements'*, specifically AT-C Section 105, '*Concepts Common to All Attestation Engagements*' and AT-C Section 205, '*Assertion – Based Examination Engagements*,' considers the direct and indirect impact of risks and controls that Anthropic's management has determined are likely to be relevant to its user entities' internal controls intended to mitigate risks related to security, availability, processing integrity, confidentiality, or privacy.

Trust Services Categories and Related Criteria

The five attributes of a system are known as *categories*, and they are defined as follows:

- *Security*: Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

  Security refers to the protection of

  i. information during its collection or creation, use, processing, transmission, and storage and

  ii. systems that use electronic information to process, transmit or transfer, and store information to enable the entity to meet its objectives. Controls over security prevent or detect the breakdown and circumvention of segregation of duties, system failure, incorrect processing, theft or other unauthorized removal of information or system resources, misuse of software, and improper access to or use of, alteration, destruction, or disclosure of information.

- *Availability*: Information and systems are available for operation and use to meet the entity's objectives.

  Availability refers to the accessibility of information used by the entity's systems, as well as the products or services provided to its customers. The availability objective does not, in itself, set a minimum acceptable performance level; it does not address system functionality (the specific functions a system performs) or usability (the ability of users to apply system functions to the performance of specific tasks or problems). However, it does address whether systems include controls to support accessibility for operation, monitoring, and maintenance.

- *Processing Integrity*: System processing is complete, valid, accurate, timely, and authorized to meet the entity's objectives.

  Processing integrity refers to the completeness, validity, accuracy, timeliness, and authorization of system processing. Processing integrity addresses whether the system achieves the aim or purpose for which they exist and whether they perform their intended functions in an unimpaired manner, free from error, delay, omission, and unauthorized or inadvertent manipulation. Because of the number of systems used by an entity, processing integrity is usually only addressed at the system or functional level of an entity.

- *Confidentiality*: Information designated as confidential is protected to meet the entity's objectives.

  Confidentiality addresses the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives. Information is confidential if the custodian of the information is required to limit its access, use, and retention and restrict its disclosure to defined parties (including those who may otherwise have authorized access within its system boundaries). Confidentiality requirements may be contained in laws or regulations or in contracts or agreements that contain commitments made to customers or others. The need for information to be confidential may arise for many different reasons.

Downloaded at Fri, 11 Apr 2025 15:06:02 GMT
Downloaded by asadq@cloudcomstudio.com

Confidentiality is distinguished from privacy in that privacy applies only to personal information, whereas confidentiality applies to various types of sensitive information. In addition, the privacy objective addresses requirements regarding collection, use, retention, disclosure, and disposal of personal information. Confidential information may include personal information as well as other information, such as trade secrets and intellectual property.

- *Privacy*: Personal information is collected, used, retained, disclosed, and disposed to meet the entity's objectives.

Although the confidentiality criteria apply to various types of sensitive information, privacy applies only to personal information.

The privacy criteria are organized into eight categories:

a. *Notice and communication of objectives.* The entity provides notice to data subjects about its objectives related to privacy.
b. *Choice and consent.* The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to data subjects.
c. *Collection.* The entity collects personal information to meet its objectives related to privacy.
d. *Use, retention, and disposal.* The entity limits use, retention, and disposal of personal information to meet its objectives related to privacy.
e. *Access.* The entity provides data subjects with access to their personal information for review and correction (including updates) to meet its objectives related to privacy.
f. *Disclosure and notifications.* The entity discloses personal information, with the consent of the data subjects, to meet its objectives related to privacy. Notification of breaches and incidents is provided to affected data subjects, regulators, and others to meet its objectives related to privacy.
g. *Quality.* The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet its objectives related to privacy.
h. *Monitoring and enforcement.* The entity monitors compliance to meet its objectives related to privacy, including procedures to address privacy-related inquiries, complaints, and disputes.

The trust services criteria may be used when evaluating the suitability of the design and operating effectiveness of controls relevant to the security, availability, or processing integrity of information and systems, or the confidentiality or privacy of the information processed by the entity. As such, they may be used when evaluating whether the entity's controls were effective to meet the criteria relevant to any of those categories, either individually or in combination with controls in other categories.

Scope

The scope that management has determined appropriate for the AI Services system includes the controls to meet the applicable trust services criteria. Management is responsible for the identification of risks associated with the system of controls, and for the design and operation of controls intended to provide reasonable assurance that the applicable trust services criteria would be met.

As part of its overall SOC 2® program, Anthropic's management sets and determines the scope and timing of each report. This description of the system has been prepared by Anthropic's management, headquartered in San Francisco California, to provide information on controls applicable to meet the trust services criteria for Security, Availability, and Confidentiality.

Downloaded on Fri, 11 Apr 2025 16:56:03 GMT
Downloaded by saad@cloudsecurityolstudio.com

Sub-Service Organizations

Anthropic uses Google LLC, a sub-service organization, for cloud hosting services through its Google Cloud Platform (GCP). The description indicates that complementary sub-service organization controls that are suitably designed and operating effectively are necessary, along with controls at Anthropic, to achieve Anthropic's service commitments and system requirements based on the applicable trust services criteria. The description presents Anthropic's controls, the applicable trust services criteria, and the types of complementary sub-service organization controls assumed in the design of Anthropic's controls. The description does not disclose the actual controls at the sub-service organization.

Significant Changes during the Examination Period

Management is not aware of any significant changes that occurred during the examination period.

Subsequent Events

Management is not aware of any relevant events that occurred subsequent to the period covered by management's description included in Section 3 of this report through the date of the service auditor's report that would have a significant effect on management's assertion.

System Incidents

Management is not aware of any system incidents that (a) were the result of controls that were not suitably designed or operating effectively or (b) otherwise resulted in a significant failure in the achievement of one or more service commitments and system requirements during the period covered by management's description included in Section 3 of this report.

Using the Work of the Internal Audit Function

The service auditor did not utilize any work of an Internal Audit function in preparing this report.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

OVERVIEW OF OPERATIONS AND THE SYSTEM

Company Overview and Background

Anthropic is an artificial intelligence (AI) startup and public-benefit corporation, founded in 2021. Anthropic specializes in developing general AI systems and language models, with a company ethos of responsible AI usage. The company was created with the goal of building beneficial artificial intelligence aligned with human values and priorities. Anthropic uses a technique called Constitutional AI to train language models via natural language feedback to be helpful, harmless, and honest. The company translates their research into tangible, practical tools, to benefit businesses, nonprofits, civil society groups, as well as people around the globe.

Overview of the AI Services system

Anthropic's AI services are provided via their own AI assistant, Claude. Anthropic's Console consists of a chat interface that allows users to interact with Claude via natural language. Natural language is any language that has evolved naturally in humans through use and repetition without conscious planning or premeditation. It's geared to help customers with tasks such as processing text, engaging in dialogue, and handling a variety of basic instructions and logical scenarios. Anthropic also provides an Application Programming Interface (API) that can be integrated into customer applications. Both the Console and API were designed with security in mind at the outset.

Users interact with the API via the POST method and authenticate using secret API keys. The POST method is designed to send loads of data to a server from a specified resource. Anthropic processes API calls using its machine learning (ML) inference infrastructure on GCP and returns the generated response in a streaming manner via Server-Sent Events (SSE). Console prompts and responses are sent over hypertext transfer protocol secure (HTTPS) / transport layer security (TLS). Users of the Console are authenticated using OAuth, which means that no user login credentials are stored on Anthropic's end.

Principal Service Commitments and System Requirements

Anthropic's management designs its processes and procedures related to the AI Services system to meet its objectives. Those objectives are based on the service commitments that Anthropic's management makes to user entities; the laws and regulations that govern the provisioning of the AI Services system; and the financial, operational, and compliance requirements that Anthropic has established for the services.

Anthropic's service commitments and system requirements may be explicitly stated within Service Level Agreements (SLAs) and contracts, or may be implicitly agreed to, based on the nature of the industry in which they operate. These commitments generally include the following:

Trust Services Category	Service Commitments	System Requirements
Security	➢ System access is granted to authorized personnel only ➢ Identification and remediation of security incidents / events	➢ Logical access standards ➢ Incident management standards
Availability	➢ Monitoring of security events ➢ Ability to recover and restore data	➢ System monitoring ➢ Backup and recovery standards

Downloaded at Fri, 11 Apr 2025 16:36:03 GMT
Downloaded by usaccounts@uhuddcontrolstudio.com

Trust Services Category	Service Commitments	System Requirements
Confidentiality	➢ Confidentiality statements are executed by employees ➢ Formal data storage requirements	➢ Employee management standards ➢ Data retention standards ➢ Encryption standards

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

OVERVIEW OF RELEVANT INFRASTRUCTURE

The AI Services system is comprised of the following components:

- Infrastructure – the physical structures, information technology (IT), and other hardware
- Software – the application programs and IT system software that supports application programs
- People – the personnel involved in the governance, operation, and use of a system
- Procedures – the automated and manual procedures
- Data – transaction streams, files, databases, tables, and output used or processed by the system

Infrastructure

The Anthropic platform is hosted utilizing GCP and the organization maintains a zero-trust security model. Anthropic does not have inherent access to infrastructure like businesses that use in-house datacenters and networks, site-to-site virtual private networks (VPNs), and other resources. Access is facilitated solely through authentication and not implicitly due to network connection, location, or status. Access and authorization into networks hosting Anthropic services are managed through Anthropic's central identity provider (IdP) with time-limited access and includes multi-factor authentication (MFA) by default. Internal networks are protected by configured firewalls with deny-by-default routing and workloads that are protected by endpoint monitoring.

Cloud workloads and those housing customer data and services are containerized and logically separated. The backend lives in a managed Kubernetes cluster integrated with cloud platform access controls; the frontend is a serverless containerized service with further restricted access controls.

The following describes the in-scope components supporting the AI Services system:

System / Application	Description	Infrastructure
Claude	AI assistance used for processing text, engaging in dialogue, and handling a variety of basic instructions and logical scenarios. Claude is also able to integrate with customer applications.	<u>Operating Systems:</u> Linux <u>Databases:</u> Google Cloud Storage Big Query <u>Web / Application Servers:</u> Google Kubernetes Engine

Software

Anthropic's system refers to the guidelines and activities for providing transaction processing and other services to user entities and includes the infrastructure and software that support Anthropic's AI Services.

- **Google Cloud –** Google Cloud Platform (GCP), and in turn the Google Cloud Console and command line interface, is used to serve Anthropic's infrastructure.
- **Google Workspace –** Google Workspace is a service that provides productivity tools, collaboration tools, and file sharing. Anthropic mainly uses Google Workspaces as an IdP and communication tool.
- **CrowdStrike –** CrowdStrike is a security software that is used for protecting endpoints, cloud workloads, identities, and data.
- **Jira –** Jira is an internal ticketing and service request management system.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

- **GitHub –** GitHub is a version control and codebase management tool, which provides a platform for approval.
- **OpsGenie –** OpsGenie is for on-call alerting for incident response.
- **Slack –** Slack is used for internal communication as well as external partner communication.
- **Kandji –** Kandji is a mobile device management platform used to manage Anthropic's end-user devices.
- **Vanta –** Vanta is a software product that helps companies manage the governance of risk and compliance processes.

People

The roles and responsibilities of key functional heads include the following:

- **Chief Executive Officer (CEO):** The CEO leads the development and execution of the company's long-term strategy. The CEO is ultimately responsible for vision setting, fundraising, closing key deals with external parties, as well as U.S. government relations.
- **President:** The President is responsible for overseeing people functions, providing business guidance, and acting as the company's operations principal. As part of this role, they provide cultural leadership and set the standards for operational excellence, recruitment, and retention of qualified staff. The President also currently manages operational and engineering leaders.
- **Chief Information Security Officer (CISO):** The CISO oversees strategic, operational, and budgetary aspects of data management and protection. This role works closely with fellow executives to develop information security policies and procedures for the organization. The CISO is the senior level executive responsible for establishing and maintaining the enterprise vision, strategy, and program to ensure information assets and technologies are adequately protected.
- **General Counsel:** The General Counsel provides legal advice and services to the organization. The General Counsel ensures company practices are compliant with any relevant data privacy and information security laws and regulations (e.g., GDPR, CCPA) and adhere to company adopted information security and data privacy standards and frameworks.
- **Chief Science Officer (CSO):** The primary responsibilities of the CSO include defining research priorities for the company, currently (and temporarily) leading the product organization, and indirectly managing one-third of the staff.

Procedures

Anthropic's management is responsible for maintaining and implementing information technology general computer controls related to computer processing supporting the AI Services. These controls provide the basis for reliance on information / data from the systems used by user entities.

Anthropic's management maintains a set of policies, processes, and procedures that establish the rules of conduct within the organization and outline the responsibilities of employees, contractors, and employers as well as prevent, detect, and treat violations and risks. These policies and procedures are updated annually, communicated company-wide, and are acknowledged by Anthropic's employees to ensure awareness of their responsibilities. The following policies contain relevant controls:

- Information Security Policy
- Acceptable Use Policy
- Physical Security Policy
- Backup Plan
- Business Continuity / Disaster Recovery Plan
- Data Management Policy
- HIPAA Compliance Policy
- Incident Response Plan
- Risk Management Policy
- Third Party Management Policy

Downloaded on Thu, 11 Apr 2024 15:56:09 GMT
Downloaded by Research@thecontrolstudio.com

Information Security

Information security policies have been established to set the overall framework for managing security of the IT infrastructure and applications supporting Anthropic's services. These policies are approved at the executive management level and establish standards for information security throughout Anthropic. The CISO has the primary responsibility for interpreting these standards and works in conjunction with Anthropic's various teams and internal stakeholders in developing procedures and processes for implementing the standards and overseeing logical security for IT and applications.

Logical and Physical Access

User administration processes for IT systems and applications are tied to the new hire, termination, and role change processes established by Anthropic. Access to the application is restricted via a unique username and password. Role based permissions are used to restrict access to the application. Internal IT access requests are approved by management prior to granting access to system accounts. Specific access based on job roles is identified during the onboarding process and access is restricted to the minimum necessary. Accounts assigned to terminated employees are disabled or removed and physical assets are returned as part of the termination process. Checklists are used to guide the task owners through each step in the onboarding and termination process. Quarterly, logical access privileges are reviewed by management to confirm that access is assigned commensurate with job roles. Although a significant portion of personnel work remotely, a physical security policy is in place and maintained by management to guide and communicate relevant facility security and visitation procedures to personnel.

The cloud production system's access authentication parameters are configured to require a unique user identification (ID), complex password, and two-factor authentication (2FA). A Clear Desk Policy and a Removable Media Policy are in place defining the responsibilities of personnel.

Network Security

A network diagram is maintained that defines segmentation boundaries and communication paths between system resources. A firewall is configured to deny traffic and only allow specific services to a specific destination. A demilitarized zone (DMZ) is configured within the firewall to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports. Access to administer the firewalls is restricted to authorized personnel commensurate with their job roles and responsibilities.

Systems Operations

Enterprise monitoring tools are used to monitor network events and application performance. Real-time visualization dashboards and defined alerts are configured to alert system administrators when early warning thresholds are crossed on key operational metrics. Security systems are deployed on production servers to protect systems from malicious software and files.

Anthropic maintains an asset inventory that includes hardware components to catalog where confidential data is stored. Patch management software is utilized to monitor current patch levels of servers and ensure systems are protected. Management takes a risk-based approach to prioritize security patches. Critical security patches are reviewed and implemented by system administrators.

Anthropic utilizes an automated vulnerability scanning system to identify weaknesses and vulnerabilities within the production systems. Security software is utilized to perform scanning and signature updates on servers. Vulnerability scanning is also configured to be performed weekly. The scanning system is configured to alert personnel of identified vulnerabilities. Personnel are alerted of low-risk vulnerabilities through Slack and a paging system is integrated with the scanning system to alert personnel of high-risk vulnerabilities. Vulnerabilities are prioritized using a risk-based approach and a ticketing system is utilized to track vulnerabilities from identification to resolution.

Downloaded by [redacted] on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by [redacted]@[redacted]controlstudio.com

Incident Response / Disaster Recovery Plan

An incident response program has been established to govern and provide a framework for managing the response and consequences of a breach in security resulting in the disclosure of client information from Anthropic systems. Suspected security incidents are reported through the IT ticketing system which is also used to monitor and track reported security incidents from identification to resolution.

To respond to an intrusion or incident, predetermined teams are assigned to resolve the issue depending on the incident's characteristics. Incidents are handled at the lowest escalation level to reduce the total impact and maximize use of available technical resources. If the expected impact of an incident is determined to be of a higher significance, alternative technical teams are called upon to contribute to the incident response resolution. The incident response process is an escalation process, meaning as the impact of the incident becomes more significant or widespread, the escalation level increases; additional resources are assigned to the incident to address the problem as needed. An assessment of major incidents is performed through root-cause analysis to prevent similar incidents. Incident response procedures are tested annually to evaluate the effectiveness of the incident response plan in reporting, escalating, and remediating security incidents.

A Disaster Recovery (DR) plan is in place and available to guide personnel in the event of unexpected disruption in operations. The DR plan defines recovery roles and responsibilities, notification requirements, critical systems and processes, and the recovery time objectives necessary. The DR plan is tested at least annually to evaluate the plan's effectiveness in responding to events that affect the continuity of services. The results of the DR test are reviewed by management and updates to the DR plan are made as needed.

Change Management

Management has defined a process to apply changes, upgrades, or modifications to the production environment. This covers changes to the infrastructure, software, or applications. A change management ticketing system is utilized to facilitate and document the change management process. Software development and version control software is utilized to maintain and store source code, and track and prioritize changes to the production environment.

The GitHub source code repository has a protected main branch with only the code owner groups having the ability to merge pull requests to the main (production) branch. Automated testing of development changes is performed in a staging environment prior to deployment into production. Development and quality assurance (QA) testing are performed in a separate environment and customer data is not used for these purposes.

Application code and infrastructure changes are approved prior to deployment to the production environment to ensure the changes are functioning as designed without unintended results. GitHub is configured to prevent changes from being promoted without authorized approval. Once QA testing has been completed and approval has been given, the change is promoted to the production branch. The ability to push changes to the production branch at Anthropic is restricted to a limited set of authorized team members defined in GitHub. Changes that affect internal users are communicated via email distribution groups.

Downloaded by Asad@cloudcontrolstudio.com at Fri Apr 11 2025 16:56:06 GMT

Data

A network diagram is used to illustrate the segmentation boundaries and communication paths between system resources. Data in transit between employee workstations and the production and development environments are encrypted via Secure Shell (SSH), or Secure Socket Layer (SSL) / TLS connections.

Anthropic maintains policies and procedures for data management to guide personnel in classifying, handling, retention, and disposal of data. The data classification procedures define the risk classifications of information. Information is classified into one of the three below categories:

- Confidential: Highly sensitive data requiring the highest levels of protection; access is restricted to specific employees or departments, and these records can only be passed to others with approval from the data owner, or a company executive.
- Restricted: Anthropic proprietary information requiring thorough protection; access is restricted to employees with a "need-to-know" based on business requirements. This data can only be distributed outside the company with approval.
- Public: Documents intended for public consumption which can be freely distributed outside Anthropic.

Anthropic utilizes a risk-based approach when granting access to data. Access is restricted on a need-to-know basis. Anthropic also utilizes encryption technology to prevent unauthorized access to data. Encryption is utilized to protect data in transit as well as at rest.

The destruction / disposal of data and media is tracked internally to maintain an audit trail. Anthropic retains data as long as the company has a need for its use, or to meet regulatory or contractual requirements. Once data is no longer needed, it is securely disposed of or archived. Data owners, in consultation with legal counsel, may determine retention periods for their data. Anthropic assesses the data and disposal practices of third-party vendors in accordance with the Third-Party Management Policy. Only third parties who meet Anthropic requirements for secure data disposal are used for storage and processing of restricted or confidential data.

<u>Backups</u>

Backup and recovery policies and procedures are documented to guide personnel in backup activities including performing, retaining, and testing backups. An automated job schedular is configured to perform backups daily on internal production databases for replication to ensure that confidential company information is protected, secure, and available. The backups are encrypted as well as stored separately from the primary data source. Backups are configured to be retained for 14 days. Anthropic performs a backup restoration test annually to evaluate the recoverability of the system in the event of a disaster or system incident.

Downloaded at Fri, 14 Mar 2025 10:18:03 GMT
Downloaded by sarah@cloudcomplistudio.com

RELEVANT ASPECTS OF CONTROL ENVIRONMENT, RISK ASSESSMENT, INFORMATION AND COMMUNICATIONS SYSTEMS, AND MONITORING

Control Environment

The control environment sets the tone of an organization, influencing the control consciousness of its people. It is the foundation for other components of internal controls, providing discipline and structure. Aspects of Anthropic's control environment that affect the services provided and / or the system of controls are identified in this section.

Integrity and Ethical Values

The effectiveness of controls is greatly influenced by the level of integrity and ethical values of the people who create, administer, and monitor them. Integrity and ethical values are important elements of Anthropic's control environment, affecting the design, administration, and monitoring of other components. The communication and implementation of ethical behavior throughout the organization is designed to reduce the likelihood of personnel engaging in dishonest, illegal, or unethical acts. A Fraud Hotline is available to employees to report complaints and issues of non-compliance with company policies.

Anthropic's management enforces high ethical standards throughout the levels of communication to and through its employees. Anthropic's management continuously audits its employees' communication with customers and outside resources to ensure compliance with these standards and addresses any issues as soon as they arise. Management emphasizes high standards during its interpersonal communications via meetings, email, and phone calls. Any questionable acts are dealt with timely and positive acts are recognized and acknowledged in public forums to reinforce positive / constructive behaviors. Employees who violate these standards are disciplined according to company policies.

Executive Management

On an annual basis executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments. Anthropic's control consciousness is influenced significantly by its Executive Management. Attributes include the Executive Management's independence from management, the experience and stature of its members, the extent of its involvement and scrutiny of activities, the appropriateness of its actions, the degree to which difficult questions are raised and pursued with management, and its interaction with internal and external auditors. Weekly, Executive Management meets to discuss business objectives and establish company direction.

Commitment to Competence

Management has established a framework for the basic skills necessary to perform each of the jobs at Anthropic. This framework is then augmented with more specific requirements for each position and for additional specialization within each position based upon any other skills an employee may have. The job descriptions for each position are descriptive but remain fairly broad because of the nature of the work for which each position is responsible. The employee understands that there are general skills that people within their given role should have and that the job description augments those skills. Upon hire, employees are required to complete security awareness training, sign acceptance of the Information Security Policy, and sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties. Annually, employees are required to complete security awareness training. Policies are required to be re-signed annually or after a material change to a given policy.

Downloaded on Fri, 11 Apr 2025 06:03 GMT
Downloaded by aegis@cloudcontrolstudio.com

Management's Philosophy and Operating Style

Anthropic's management philosophy and operating style is ultimately responsible for the system of internal controls. Employees have some role in controlling the organization. Some controls are established at the organization level, and management of the local unit establishes others. Management has formal policies and procedures in place to guide personnel on specific information processing functions.

Organizational Structure

Management has designed the organizational structure to provide quality service and accountability in support of Anthropic's mission. To achieve quality in performance, they strive for continuous improvement in what is done, plan and commit to accomplish targets, and are empowered to perform their duties. Anthropic's operations are highly specialized and require the ability to adapt to industry changes and best practices. Anthropic has a centralized, flat management framework, which allows them to quickly react to industry changes and have excellent response times to customer needs. In addition, the President is an active participant in day-to-day operations. Organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel. These charts are available for personnel via the HR system. In addition, a fraud hotline is available to employees to report complaints and issues of non-compliance with company policies.

Human Resource Policies and Practices

Anthropic's human resource policies and practices are clearly written and communicated where appropriate. Policies and procedures that are listed in the employee handbook include hiring, training, disciplinary actions, and termination procedures. Anthropic demonstrates a commitment to retain competent individuals beginning at the onboarding process. Prior to granting access to the systems, background screenings are performed for candidates. After an offer has been extended and accepted, a new hire checklist ticket is followed to ensure consistency in the onboarding process. The onboarding process includes the completion of security awareness training and the candidate's written commitment to comply with policies and procedures set forth by management. Management performs annual formal performance reviews for applicable positions. Management has designed these policies and procedures to lay a groundwork for fairness that, in combination with an expectation of performance from employees, will ensure a long-term culture of respect. For voluntary or involuntary employee terminations, procedures are documented in a termination checklist to guide personnel during the off-boarding process.

Downloaded by ssingh@secondnaturecontrolstudio.com Fri, 12 Dec 2025 15:56:03 GMT

Risk Assessment

Risk assessment is the process of identifying and analyzing relevant risks which, if realized, could prevent Anthropic's management from achieving its operational compliance objectives. Anthropic has a defined risk methodology and standards in place for the treatment of risks throughout the environment. Management assesses and manages risk that could affect the organization's ability to provide services to its clients on an ongoing basis. For any significant risks identified, management is responsible for implementing appropriate measures to remediate or manage these risks to acceptable levels.

Anthropic has secured a Governance, Risk, and Compliance ("GRC") platform to assess, monitor, and remediate risks. Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements. The risk assessment involves team representatives (department leads) to ensure risks are identified from various areas of the company. As part of that program and the processes around it, the company considers both risk appetite and tolerance. After determining pertinent risks, Anthropic assesses likelihood and impact of risks. The risk is assigned treatment options including acceptance, mitigation, transference, or avoidance. The portfolio includes mapping of controls common to various risk management and other frameworks to provide a unified system to monitor and address risk. A residual risk rating is established that takes mitigation strategies / controls into consideration. Risks owners are assigned by business units and the results of the risk assessment are reviewed with senior management.

Downloaded on, 11 Apr 2025 15:56:03 GMT
asad@cloudcontrolstudio.com

Information and Communication Systems

Information System

Anthropic's management has documented an information security policy to help ensure that employees understand their individual roles and responsibilities concerning processing and controls to ensure significant events are communicated in a timely manner. These include formal and informal training programs and the use of email to communicate time sensitive information and processes for security and system availability purposes that notify key personnel in the event of potential security issues or system outages.

Communication System

Management is involved with day-to-day operations and provides personnel with an understanding of their individual roles and responsibilities. This includes the ability to provide necessary training to the extent that personnel understand how their daily activities and roles relate to the overall support of services. Anthropic's management believes that open communication throughout the organization ensures that deviations from standards are identified, reported, and appropriately addressed. The organization's privacy policy is made available to external parties via the company website. Security commitments are also communicated through the Terms of Use policy, which is available on the customer facing website.

Downloaded on, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

Monitoring

On-Going Monitoring

Anthropic's management performs monitoring activities to assess the quality of internal control over time, monitors activities throughout the year, and takes corrective actions to address deviations from company policy and procedures. Management utilizes a risk-based approach to monitor business units and other auditable entities throughout the organization, ensuring that enterprise-wide risks are prioritized and addressed in order of significance.

Management is proactive in responding to customer complaints and there is a high level of inter-departmental communication about these events. Customer complaints and other issues are handled without undue delay via an internal ticketing system. Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.

Vendor and Sub-Service Organization Monitoring

Management recognizes that the development of relationships with vendors creates a way to offer certain products and services to its clients that would not otherwise be available in the same high-performance, cost-effective manner. Management also recognizes that vendor relationships present potential risks that should be properly managed on an ongoing basis. In response to this risk, Anthropic's management has implemented a vendor management program including policies to define the requirements necessary for the onboarding and monitoring of vendors.

Anthropic performs due diligence activities prior to onboarding new service providers to determine if they can meet organizational standards and obligations once under contract. The requestor for a new vendor completes a threat analysis as well as submits a formal request to management, which is reviewed by the Security Engineer. Once the initial due diligence has been completed and Anthropic is ready to onboard a new service provider, agreements are required to be executed. Contract agreements, including Business Associate Agreements (BAAs) are executed with services with access to sensitive data that define the responsibility of each party as it relates to the security, availability, and confidentiality of data. For managed service providers that support critical production environment components, SLAs are required to be executed. Vendors are also required to sign a Non-Disclosure Agreement (NDAs) as part of the onboarding process.

An inventory of vendors is maintained to track the status of active service providers that are employed by the organization. Contracted vendors are evaluated annually, and the results are recorded, tracked, and discussed by management. As part of the annual review, management reviews the threat level for each vendor and updates to the risk level are made as needed. As part of the annual review, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.

Downloaded by: 11 Apr 2026 15:08:03 GMT
Downloaded by: saad@hdcoolstudio.com

CATEGORIES, CRITERIA, AND RELATED CONTROLS

The categories, criteria, and related controls are included in Section 4 of this report, “Categories, Criteria, Related Controls and Tests of Operating Effectiveness”, to eliminate the redundancy that would result from listing them in this section and repeating them in Section 4. Although the criteria and related controls are included in Section 4, they are, nevertheless, an integral part of the organization’s description of controls.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

COMPLEMENTARY CONTROL CONSIDERATIONS

Anthropic's controls do not depend on the implementation of Complementary User Entity Controls (CUECs) at user entities to meet their service commitments and requirements; however, user entities are responsible for performing certain activities to benefit from Anthropic's AI Services system.

Anthropic's control policies and procedures were designed with the assumption that certain controls would be in place and in operation at the sub-service organization. Sub-service organization controls must be evaluated, taking into consideration Anthropic's controls and their own internal controls. Anthropic's management does not make any representations regarding responsibility related to or provide any assurance regarding any such internal control or regulatory requirements for which the client must assess or comply.

This section describes some of the control considerations for the sub-service organization, or "complementary controls", which should be in operation at the sub-service organization to complement the controls at the service organization. User auditors / user entities should determine whether the sub-service organization has established controls to ensure that the criteria within this report are met. The "complementary controls" presented below should not be regarded as a comprehensive list of all controls that should be employed by the sub-service organization.

Complementary Sub-Service Organization Controls

1. The sub-service organization is responsible for having physical and logical security controls in place to ensure access to data centers and storage facilities are limited to authorized personnel and that information systems are protected from unauthorized access, damage, and interference.
2. The sub-service organization is responsible for having environmental security and monitoring controls in place to ensure that critical information technology infrastructure is protected from identified threats.
3. The sub-service organization is responsible for notifying Anthropic, in a timely manner, when changes are made to technical or administrative controls impacting Anthropic systems.
4. The sub-service organization is responsible for the secure destruction of decommissioned equipment.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

SECTION 4:

CATEGORIES, CRITERIA, CONTROL DESCRIPTIONS, RELATED CONTROLS AND TESTS OF OPERATING EFFECTIVENESS

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

INFORMATION PROVIDED BY THE SERVICE AUDITOR

Introduction

This report is intended to provide user entities, prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators who have sufficient knowledge and understanding with information about controls that may affect the AI Services system provided by Anthropic and to provide information about the operating effectiveness of controls that were tested.

The scope of our testing of Anthropic's controls was limited to the categories, criteria, and the related controls specified by Anthropic's management and contained within Section 4 of this report, which management believes to be the relevant key controls for the categories and criteria included in the scope of this report. Our review was not extended to controls in place at any user entities, the sub-service organization, or any other third-party vendors.

The examination was performed in accordance with the American Institute of Certified Public Accountants (AICPA) Statement on Standards for Attestation Engagements No. 21 '*Direct Examination Engagements*', specifically AT-C Section 105, "*Concepts Common to All Attestation Engagements*' and AT-C Section 205, '*Assertion – Based Examination Engagements*.' It is each interested party's responsibility to evaluate this information in relation to controls in place at user entities and the sub-service organization to obtain an overall understanding of internal control and to assess control risk. Controls in place at user entities, the sub-service organization, and Anthropic must be evaluated together. A general, but not inclusive, listing of control considerations is provided in Section 3, "Complementary Control Considerations." If an effectively operating user entity or sub-service organization internal control is not in place, the controls at Anthropic may not sufficiently compensate for the deficiency.

Tests of Operating Effectiveness

Our tests of the operating effectiveness of the controls specified by Anthropic's management included such tests as we considered necessary in the circumstances to obtain reasonable, but not absolute, assurance that the controls operated in a manner that achieved the specified criteria during the period from April 16, 2023 to September 30, 2023. In selecting particular tests of the operating effectiveness of controls we considered 1) the nature of the controls being tested; 2) the types and completeness of available evidential matter; 3) the nature of the criteria to be achieved; 4) the assessed level of control risk; 5) the expected efficiency and effectiveness of the test; and 6) the testing of other controls relevant to the criteria.

Testing exceptions, if any, and information about specific tests of the operating effectiveness performed that may be relevant to the interpretation of testing results by user entities, prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators who have sufficient knowledge and understanding for the controls specified to achieve the criteria are presented in this section under the column heading "Results of Testing." The concept of materiality is not applied when reporting the results of the tests of controls for which exceptions have been identified because the independent service auditor does not have the ability to determine whether an exception will be relevant to a particular user entity. Consequently, 360 Advanced, Inc. reports all exceptions. Exceptions identified herein are not necessarily considered significant deficiencies or material weaknesses in the total system of internal controls of Anthropic, as this determination can only be made after consideration of controls in place at user entities. Control considerations that should be exercised by Anthropic's clients to complement the controls of Anthropic to attain the criteria are presented in relation to the nature of services being audited and the controls specified by Anthropic management.

Downloaded by at Fri, 11 Apr 2025 15:56 GMT
Downloaded by aaa@cloudanthropic.com

Types of Tests Performed

The table below describes the nature of our audit procedures and tests performed to evaluate the operational effectiveness of the controls detailed in the matrices that follow:

Test Types	Description of Tests
Inquiry	Inquired of appropriate personnel seeking relevant information or representation to obtain the following information about the control: ➢ Knowledge and additional information regarding the policy or procedure; and ➢ Corroborating evidence of the policy or procedure.
Inspection	Inspected documents and records indicating performance of the control. This includes, but is not limited to, the following: ➢ Examination / Inspection of source documentation and authorizations to verify transactions processed; ➢ Examination / Inspection of documents or records for evidence of performance, such as existence of initials or signatures; ➢ Examination / Inspection of systems documentation, configurations and settings; and ➢ Examination / Inspection of procedural documentation such as operations manuals, flow charts and job descriptions.
Observation	Observed the implementation, application or existence of specific controls as represented
Re-performance	Re-performed the control to verify the design and / or operation of the control activity as performed

Procedures for Assessing Completeness and Accuracy of IPE

For tests of controls requiring the use of Information Provided by the Entity ("IPE") (e.g., controls requiring system generated populations for sample-based testing), 360 Advanced, Inc. performed a combination of the following procedures, where possible, based on the nature of the IPE to address the completeness, accuracy, and data integrity of the data or reports used: (1) inspected the source of the IPE, (2) inspected the query, script, or parameters used to generate the IPE, (3) tied data between the IPE and the source, and / or (4) inspected the IPE for anomalous gaps in sequence or timing to determine the data is complete, accurate, and maintained its integrity. In addition to the above procedures, for tests of controls requiring management's use of IPE in the execution of the controls (e.g., periodic reviews of user access listings), the independent service auditor inspected management's procedures to assess the validity of the IPE source and the completeness, accuracy, and integrity of the data or reports.

Downloaded at Fri, 11 Apr 2025 15:38:09 GMT
Downloaded by asad@cloudcomplianceaudio.com

Sampling Methodology

The table below describes the sampling methodology utilized in our testing to evaluate the operational effectiveness of the controls detailed in the matrices that follow:

Type of Control and Frequency	Minimum Number of Items to Test (Period of Review Six Months or Less)	Minimum Number of Items to Test (Period of Review More than Six Months)
Manual control, many times per day	At least 25	At least 40
Manual control, daily (Note 1)	At least 25	At least 40
Manual control, weekly	At least 5	At least 10
Manual control, monthly	At least 3	At least 4
Manual control, quarterly	At least 2	At least 2
Manual control, annually	Test annually	Test annually
Application controls	Test one operation of each relevant aspect of each application control if supported by effective IT general controls; otherwise test at least 15	Test one operation of each application control if supported by effective IT general controls; otherwise test at least 25
IT general controls	Follow guidance above for manual and automated aspects of IT general controls	Follow guidance above for manual and automated aspects of IT general controls

Notes: 1.) Some controls might be performed frequently, but less than daily. For such controls, the sample size should be interpolated using the above guidance. Generally, for controls where the number of occurrences ranges from 50 to 250 during the year, our minimum sample size using the above table should be approximately 10% of the number of occurrences.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asaad@cloudcontrolstudio.com

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@soc2controlstudio.com

CATEGORIES, CRITERIA, AND RELATED CONTROLS

Security (Common Criteria to All Categories)

Information and systems are protected against unauthorized access, unauthorized disclosure of information, and damage to systems that could compromise the availability, integrity, confidentiality, and privacy of information or systems and affect the entity's ability to meet its objectives.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
Control Environment			
CC1.1 - COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.			
CTL-026	Upon hire, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.
		Inspected the completed security awareness trainings for a sample of new hires during the examination period to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.
CTL-027	Upon hire, employees are required to sign acceptance of the Information Security Policy.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign acceptance of the Information Security Policy.	No exceptions noted.
		Inspected the information security policy acknowledgements for a sample of new hires during the examination period to verify that upon hire, employees were required to sign acceptance of the information security policy.	No exceptions noted.
CTL-028	Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the executed confidentiality acknowledgement for a sample of new hires during the examination period to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
CTL-029	Background screenings are performed for employment candidates as a component of the hiring process.	Inquired of the Senior Security and Compliance Manager to verify that background screenings were performed for employment candidates as a component of the hiring process.	No exceptions noted.
		Inspected the completed background screening for a sample of new hires during the examination period to verify that background screenings were performed for employment candidates as a component of the hiring process.	No exceptions noted.
CTL-030	Annually, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of tenured employees during the examination period to verify that employees were required to complete security awareness training within past 12 months.	No exceptions noted.
CTL-040	Management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	Inquired of the Senior Security and Compliance Manager to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	No exceptions noted.

Downloaded as Kim Lyman 2025-15:56:63 GMT
Downloaded by essap@coldfdcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the Code of Conduct to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	No exceptions noted.
CC1.2 - COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.			
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CC1.3 - COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.			
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.

Downloaded at Fri, 12 Apr 2024 15:56:02 GMT
Downloaded by cisadecisecurity@gmail.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-038	Organizational charts are used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments.	Inquired of the Senior Security and Compliance Manager to verify that organizational charts were used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments.	No exceptions noted.
		Inspected the organizational charts to verify that organizational charts were used to define the organizational structure of the company and provide reporting lines and relative ranks for positions within departments.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.

Downloaded at Mon, 14 Apr 2025 15:56:03 GMT
Downloaded by asaad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-041	A Fraud Hotline is available to employees to report complaints and issues of non-compliance with company policies.	Inquired of the Senior Security and Compliance Manager to verify that a Fraud Hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
		Inspected the whistleblower reporting form to verify that a fraud hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
CC1.4 - COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.			
CTL-026	Upon hire, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.
		Inspected the completed security awareness trainings for a sample of new hires during the examination period to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.
CTL-027	Upon hire, employees are required to sign acceptance of the Information Security Policy.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign acceptance of the Information Security Policy.	No exceptions noted.

Downloaded at 11:12 Apr 2025 15:56:03 GMT
Downloaded by asad@securitytoolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the information security policy acknowledgements for a sample of new hires during the examination period to verify that upon hire, employees were required to sign acceptance of the information security policy.	No exceptions noted.
CTL-029	Background screenings are performed for employment candidates as a component of the hiring process.	Inquired of the Senior Security and Compliance Manager to verify that background screenings were performed for employment candidates as a component of the hiring process.	No exceptions noted.
		Inspected the completed background screening for a sample of new hires during the examination period to verify that background screenings were performed for employment candidates as a component of the hiring process.	No exceptions noted.
CTL-030	Annually, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of tenured employees during the examination period to verify that employees were required to complete security awareness training within past 12 months.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
CTL-049	Information security policies and procedures are documented, available to guide personnel, and updated annually.	Inquired of the Senior Security and Compliance Manager to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:02 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months.	No exceptions noted.
CC1.5 - COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.			
CTL-031	Annually, performance reviews are performed by management to ensure ongoing employee development and competency.	Inquired of the Senior Security and Compliance Manager to verify that performance reviews were performed by management on an annual basis to ensure ongoing employee development and competency.	No exceptions noted.
		Inspected the completed performance review for a sample of tenured employees during the examination period to verify that performance reviews were performed by management within the past 12 months to ensure ongoing employee development and competency.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
CTL-040	Management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	Inquired of the Senior Security and Compliance Manager to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	No exceptions noted.
		Inspected the Code of Conduct to verify that management has documented a code of business conduct and ethical standards, which includes a sanctions policy for personnel who violate the code of business conduct.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by ashadcloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-072	BAAs are executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that BAAs were executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-073	Agreements are executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that contract agreements were executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
Communication and Information			
CC2.1 - COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.

Downloaded by [redacted] at Fri, 10 Apr 2025 15:56:03 GMT
Downloaded by [redacted]@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
CTL-024	A network diagram is maintained that defines segmentation boundaries and communication paths between system resources.	Inquired of the People Operations Manager to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
		Inspected the network diagram to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.

Downloaded at 11:19 Apr 2025 15:56:03 GMT
Downloaded by asad@vigilantcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
CC2.2 - COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.			
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.

Downloaded by aadeeduocontrolstudio.com
Downloaded on Fri, 11 Apr 2025 15:56:03 GMT

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-028	Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Inspected the executed confidentiality acknowledgement for a sample of new hires during the examination period to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:63 GMT
Downloaded by ssaatchi@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
CTL-049	Information security policies and procedures are documented, available to guide personnel, and updated annually.	Inquired of the Senior Security and Compliance Manager to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis.	No exceptions noted.
		Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded on Mar 11, 2025 15:56:02 GMT
Downloaded by asad@clouddcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC2.3 - COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.			
CTL-023	Executed agreements are maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	Inquired of the IT Security Team to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
		Inspected the executed agreement for a sample of onboarded clients during the examination period to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
CTL-057	SLAs are in place with the managed services providers that support the critical components within the production environment.	Inquired of the Senior Security and Compliance Manager to verify that SLAs were in place with the managed services providers that support the critical components within the production environment.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-059	As part of the onboarding process, NDAs are executed with vendors that define the responsibilities and scope of services provided.	Inquired of the Senior Security and Compliance Manager to verify that as part of the onboarding process, agreements were executed with vendors that define the responsibilities and scope of services provided.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.

Downloaded by grade@controlstudio.com
Downloaded on Thursday, April 03, 2025 15:56:03 GMT

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
CTL-072	BAAs are executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that BAAs were executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-073	Agreements are executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that contract agreements were executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded at Fri, 01 Apr 2025 15:56:03 GMT
Downloaded by vasaga@dcuccontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-076	The organization's privacy policy is made available to external parties via the company website.	Inquired of the Senior Security and Compliance Manager to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.
		Inspected the Privacy Policy on the company website to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.
CTL-077	Security commitments are communicated through the Terms of Service which is available on the customer facing website.	Inquired of the Senior Security and Compliance Manager to verify that security commitments were communicated through the Terms of Service which was available on the customer facing website.	No exceptions noted.
		Inspected the terms of service on the company website to verify that security commitments were communicated through the terms of service which was available on the customer facing website.	No exceptions noted.
Risk Assessment			
CC3.1 - COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.

Downloaded at 11:19 Apr 1, 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-009	An asset inventory is maintained to catalog where confidential data is stored.	Inquired of the Senior Security and Compliance Manager to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.
		Inspected the asset inventory list to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.

Downloaded at Fri, 19 Apr 2024 15:56:02 GMT
Downloaded by cisadec@secureconnectstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
CC3.2 - COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-009	An asset inventory is maintained to catalog where confidential data is stored.	Inquired of the Senior Security and Compliance Manager to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.

Downloaded by [illegible] on 25 Apr 2025 15:56:03 GMT
Downloaded by [illegible]@[illegible]controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the asset inventory list to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-073	Agreements are executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that contract agreements were executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A

Downloaded by a@b.c. on 17 Apr 2025 15:56:03 GMT
Downloaded by a@b.c. on 17 Apr 2025 15:56:03 GMT
cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC3.3 - COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.

Downloaded on Fri Apr 18 2025 15:56:02 GMT
Downloaded by asad@auditcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-041	A Fraud Hotline is available to employees to report complaints and issues of non-compliance with company policies.	Inquired of the Senior Security and Compliance Manager to verify that a Fraud Hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
		Inspected the whistleblower reporting form to verify that a fraud hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
CTL-042	A cyber insurance policy is maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	Inquired of the Senior Security and Compliance Manager to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	No exceptions noted.
		Inspected the cyber insurance policy to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	No exceptions noted.
CC3.4 - COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.

Downloaded at 11:10 Apr 1 2025 15:56:03 GMT
Downloaded by asad@securitycontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.

Downloaded at 11:11 Apr 10, 2025 15:56:03 GMT
Downloaded by ssaad@secuddentrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
Monitoring Activities			
CC4.1 - COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
CTL-008	Annually, the DR plan is tested and updated.	Inquired of the Senior Security and Compliance Manager to verify that the DR plan was tested and updated on an annual basis.	No exceptions noted.
		Inspected the DR test exercise and post meeting notes to verify that the DR plan was tested and updated within past 12 months.	No exceptions noted.
CTL-055	Weekly, vulnerability scans are performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope.	Inquired of the Senior Security and Compliance Manager to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by aaaaaaaaaa@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the vulnerability scan configuration and an example of a scan to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
CC4.2 - COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.			
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:36:06 GMT
Downloaded by dean@aicpacontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-056	Help desk tickets are managed in a ticketing system to monitor status and ensure tickets are reviewed and resolved in a timely manner.	Inquired of the Senior Security and Compliance Manager to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
		Inspected the help desk ticketing system dashboard to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.

Downloaded on Fri, 11 Jul 2025 15:56:03 GMT
Downloaded by vessa@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
Control Activities			
CC5.1 - COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
CTL-026	Upon hire, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.
		Inspected the completed security awareness trainings for a sample of new hires during the examination period to verify that upon hire, employees were required to complete security awareness training.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@securitycontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-027	Upon hire, employees are required to sign acceptance of the Information Security Policy.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign acceptance of the Information Security Policy.	No exceptions noted.
		Inspected the information security policy acknowledgements for a sample of new hires during the examination period to verify that upon hire, employees were required to sign acceptance of the information security policy.	No exceptions noted.
CTL-030	Annually, employees are required to complete security awareness training.	Inquired of the Senior Security and Compliance Manager to verify that employees were required to complete security awareness training on an annual basis.	No exceptions noted.
		Inspected the completed security awareness training for a sample of tenured employees during the examination period to verify that employees were required to complete security awareness training within past 12 months.	No exceptions noted.
CTL-039	Roles and responsibilities are defined in written job descriptions.	Inquired of the Senior Security and Compliance Manager to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
		Inspected the job descriptions to verify that roles and responsibilities were defined in written job descriptions.	No exceptions noted.
CTL-049	Information security policies and procedures are documented, available to guide personnel, and updated annually.	Inquired of the Senior Security and Compliance Manager to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis.	No exceptions noted.
		Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months.	No exceptions noted.

Downloaded at Mon, 14 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC5.2 - COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.			
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-043	Patch management software is utilized to monitor current patch levels of servers.	Inquired of the Senior Security and Compliance Manager to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected a patch ticket to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.
CTL-049	Information security policies and procedures are documented, available to guide personnel, and updated annually.	Inquired of the Senior Security and Compliance Manager to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis.	No exceptions noted.
		Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months.	No exceptions noted.
CTL-055	Weekly, vulnerability scans are performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope.	Inquired of the Senior Security and Compliance Manager to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.
		Inspected the vulnerability scan configuration and an example of a scan to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.
CTL-068	The cloud production system's access authentication parameters are configured to require a unique user ID, complex password, and 2FA.	Inquired of the Senior Security and Compliance Manager to verify that the cloud production system's access authentication parameters were configured to require a unique user ID, complex password, and 2FA.	No exceptions noted.
		Inspected the cloud production system authentication configurations to verify that the cloud production system's access authentication parameters were configured to require a unique user ID, complex password, and 2FA.	No exceptions noted.

Downloaded on Mar 11, 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
CC5.3 - COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.			
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
CTL-033	Procedures are documented in a new hire checklist to guide personnel during the onboarding process.	Inquired of the Technical Staff to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process.	No exceptions noted.
		Inspected the onboarding checklist to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process.	No exceptions noted.
CTL-034	Procedures are documented in a termination checklist to guide personnel during the off-boarding process.	Inquired of the Senior Security and Compliance Manager to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process.	No exceptions noted.

Downloaded at 2025-11-11 15:56:03 GMT
Downloaded by deac@academicstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process.	No exceptions noted.
CTL-041	A Fraud Hotline is available to employees to report complaints and issues of non-compliance with company policies.	Inquired of the Senior Security and Compliance Manager to verify that a Fraud Hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
		Inspected the whistleblower reporting form to verify that a fraud hotline was available to employees to report complaints and issues of non-compliance with company policies.	No exceptions noted.
CTL-047	A data classification policy is in place that defines processes and procedures for the protection of information assets.	Inquired of the Senior Security and Compliance Manager to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets.	No exceptions noted.
		Inspected the Data Management Policy to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets.	No exceptions noted.
CTL-048	Policies and procedures for the retention and destruction of information assets are maintained and available to guide personnel.	Inquired of the Senior Security and Compliance Manager to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
		Inspected the Data Management Policy to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
CTL-049	Information security policies and procedures are documented, available to guide personnel, and updated annually.	Inquired of the Senior Security and Compliance Manager to verify that information security policies and procedures were documented, available to guide personnel, and updated on an annual basis.	No exceptions noted.

Downloaded at 11:11 Apr 2025 15:56:03 GMT
Downloaded by asad@shoaccontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the Information Security Policy and the policy storage to verify that information security policies and procedures were documented, available to guide personnel, and updated within the past 12 months.	No exceptions noted.
CTL-051	A physical security policy is maintained by management to guide and communicate relevant facility security and visitation procedures to personnel.	Inquired of the Senior Security and Compliance Manager to verify that a physical security policy was maintained by management to guide and communicate relevant facility security and visitation procedures to personnel.	No exceptions noted.
		Inspected the Physical Security Policy to verify that a physical security policy was maintained by management to guide and communicate relevant facility security and visitation procedures to personnel.	No exceptions noted.
CTL-052	A defined risk methodology is in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	Inquired of the Technical Staff to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	No exceptions noted.
		Inspected the Risk Management Policy to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	No exceptions noted.
CTL-053	A vendor management policy is documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	Inquired of the Senior Security and Compliance Manager to verify that a vendor management policy was documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	No exceptions noted.
		Inspected the Third-Party Management Policy to verify that a vendor management policy was documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by demo@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-075	A Clear Desk Policy and a Removable Media Policy are in place defining the responsibilities of Company personnel.	Inquired of the Senior Security and Compliance Manager to verify that a Clear Desk Policy and a Removable Media Policy were in place defining the responsibilities of Company personnel.	No exceptions noted.
		Inspected the Information Security Policy to verify that a clear desk policy and a removable media policy were in place defining the responsibilities of company personnel.	No exceptions noted.
Logical and Physical Access Controls			
CC6.1 The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.			
CTL-001	Access to the application is restricted via a unique username and password.	Inquired of the Senior Security and Compliance Manager to verify that access to the application was restricted via a unique username and password.	No exceptions noted.
		Inspected the google login prompt and google MFA prompt to verify that access to the application was restricted via a unique username and password.	No exceptions noted.
CTL-002	Role based permissions are used to restrict access to the application.	Inquired of the Senior Security and Compliance Manager to verify that role based permissions were used to restrict access to the application.	No exceptions noted.
		Inspected the access roles and permissions listing to verify that role based permissions were used to restrict access to the application.	No exceptions noted.
CTL-009	An asset inventory is maintained to catalog where confidential data is stored.	Inquired of the Senior Security and Compliance Manager to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.
		Inspected the asset inventory list to verify that an asset inventory was maintained to catalog where confidential data was stored.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-011	Workstations are encrypted to prevent unauthorized access to data.	Inquired of the Senior Security and Compliance Manager to verify that workstations were encrypted to prevent unauthorized access to data.	No exceptions noted.
		Inspected the workstation encryption to verify that workstations were encrypted to prevent unauthorized access to data.	No exceptions noted.
CTL-021	Encryption technology is in place to protect data during transmission and at rest.	Inquired of the Senior Security and Compliance Manager to verify that encryption technology was in place to protect data during transmission and at rest.	No exceptions noted.
		Inspected the encryption configurations to verify that encryption technology was in place to protect data during transmission and at rest.	No exceptions noted.
CTL-024	A network diagram is maintained that defines segmentation boundaries and communication paths between system resources.	Inquired of the People Operations Manager to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
		Inspected the network diagram to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
CTL-068	The cloud production system's access authentication parameters are configured to require a unique user ID, complex password, and 2FA.	Inquired of the Senior Security and Compliance Manager to verify that the cloud production system's access authentication parameters were configured to require a unique user ID, complex password, and 2FA.	No exceptions noted.
		Inspected the cloud production system authentication configurations to verify that the cloud production system's access authentication parameters were configured to require a unique user ID, complex password, and 2FA.	No exceptions noted.

Downloaded on 11 Apr 2025 15:56:03 GMT
Downloaded by dsfu@securitystudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-069	A DMZ is implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	Inquired of the Senior Security and Compliance Manager to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
		Inspected the firewall rules to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
CC6.2 Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.			
CTL-025	Internal IT access requests are approved by management prior to granting access to system accounts.	Inquired of the Senior Security and Compliance Manager to verify that internal IT access requests were approved by management prior to granting access to system accounts.	No exceptions noted.
		Inspected the role based matrix and an example of specific management and internal level clearance for a recently onboarded employee to verify that internal IT access requests were approved by management prior to granting access to system accounts.	No exceptions noted.
CTL-032	Accounts assigned to terminated employees are disabled or deleted upon termination.	Inquired of the People Operations Manager to verify that accounts assigned to terminated employees were disabled or deleted upon termination.	No exceptions noted.
		Inspected the termination ticket and date / time stamps of when access was revoked for a sample of terminated employees during the examination period to verify that accounts assigned to terminated employees were disabled or deleted upon termination.	No exceptions noted.

Downloaded at Fri, 12 Apr 2024 15:56:03 GMT
Downloaded by asad@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-054	Quarterly, logical access privileges are reviewed by management to ensure access is assigned commensurate with job roles.	Inquired of the Senior Security and Compliance Manager to verify that logical access privileges were reviewed by management on a quarterly basis to ensure access was assigned commensurate with job roles.	No exceptions noted.
		Inspected the logical access review meeting for a sample of quarters during the examination period to verify that logical access privileges were reviewed by management on a quarterly basis to ensure access was assigned commensurate with job roles.	No exceptions noted.
CC6.3 The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.			
CTL-002	Role based permissions are used to restrict access to the application.	Inquired of the Senior Security and Compliance Manager to verify that role based permissions were used to restrict access to the application.	No exceptions noted.
		Inspected the access roles and permissions listing to verify that role based permissions were used to restrict access to the application.	No exceptions noted.
CTL-025	Internal IT access requests are approved by management prior to granting access to system accounts.	Inquired of the Senior Security and Compliance Manager to verify that internal IT access requests were approved by management prior to granting access to system accounts.	No exceptions noted.
		Inspected the role based matrix and an example of specific management and internal level clearance for a recently onboarded employee to verify that internal IT access requests were approved by management prior to granting access to system accounts.	No exceptions noted.
CTL-032	Accounts assigned to terminated employees are disabled or deleted upon termination.	Inquired of the People Operations Manager to verify that accounts assigned to terminated employees were disabled or deleted upon termination.	No exceptions noted.

Downloaded at Bookmark 11 Apr 2025 15:56:03 GMT
Downloaded by dead@eclipsedcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the termination ticket and date / time stamps of when access was revoked for a sample of terminated employees during the examination period to verify that accounts assigned to terminated employees were disabled or deleted upon termination.	No exceptions noted.
CTL-033	Procedures are documented in a new hire checklist to guide personnel during the onboarding process.	Inquired of the Technical Staff to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process.	No exceptions noted.
		Inspected the onboarding checklist to verify that procedures were documented in a new hire checklist to guide personnel during the onboarding process.	No exceptions noted.
CTL-054	Quarterly, logical access privileges are reviewed by management to ensure access is assigned commensurate with job roles.	Inquired of the Senior Security and Compliance Manager to verify that logical access privileges were reviewed by management on a quarterly basis to ensure access was assigned commensurate with job roles.	No exceptions noted.
		Inspected the logical access review meeting for a sample of quarters during the examination period to verify that logical access privileges were reviewed by management on a quarterly basis to ensure access was assigned commensurate with job roles.	No exceptions noted.
CTL-070	Administrator access to the firewall system is restricted to personnel commensurate with their job role.	Inquired of the Senior Security and Compliance Manager to verify that administrator access to the firewall system was restricted to personnel commensurate with their job role.	No exceptions noted.
		Inspected the firewall administrative listing to verify that administrator access to the firewall system was restricted to personnel commensurate with their job role.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:02 GMT
Downloaded by asad@securitycontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC6.4 The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.			
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
CC6.5 The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.			
CTL-034	Procedures are documented in a termination checklist to guide personnel during the off-boarding process.	Inquired of the Senior Security and Compliance Manager to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process.	No exceptions noted.
		Inspected the offboarding checklist to verify that procedures were documented in a termination checklist to guide personnel during the off-boarding process.	No exceptions noted.
CTL-035	A Destruction Declaration is retained as evidence of the destruction of information assets.	Inquired of the Senior Security and Compliance Manager to verify that a Destruction Declaration was retained as evidence of the destruction of information assets.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by arnold@clearcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-047	A data classification policy is in place that defines processes and procedures for the protection of information assets.	Inquired of the Senior Security and Compliance Manager to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets.	No exceptions noted.
		Inspected the Data Management Policy to verify that a data classification policy was in place that defines processes and procedures for the protection of information assets.	No exceptions noted.
CTL-048	Policies and procedures for the retention and destruction of information assets are maintained and available to guide personnel.	Inquired of the Senior Security and Compliance Manager to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
		Inspected the Data Management Policy to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
CC6.6 The entity implements logical access security measures to protect against threats from sources outside its system boundaries.			
CTL-024	A network diagram is maintained that defines segmentation boundaries and communication paths between system resources.	Inquired of the People Operations Manager to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
		Inspected the network diagram to verify that a network diagram was maintained that defines segmentation boundaries and communication paths between system resources.	No exceptions noted.
CTL-069	A DMZ is implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	Inquired of the Senior Security and Compliance Manager to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.

Downloaded at Wed Apr 2025 15:56:03 GMT
Downloaded by asad@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the firewall rules to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
CC6.7 The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.			
CTL-010	The malware software is configured to perform continuous scans and signature updates on servers.	Inquired of the Senior Security and Compliance Manager to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.
		Inspected the antivirus dashboard and antivirus enabled on workstations to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.
CTL-069	A DMZ is implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	Inquired of the Senior Security and Compliance Manager to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
		Inspected the firewall rules to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
CC6.8 The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.			
CTL-010	The malware software is configured to perform continuous scans and signature updates on servers.	Inquired of the Senior Security and Compliance Manager to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.
		Inspected the antivirus dashboard and antivirus enabled on workstations to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.

Downloaded at 11:11 Mar 2025 15:56:05 GMT
Downloaded by ssaab@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-043	Patch management software is utilized to monitor current patch levels of servers.	Inquired of the Senior Security and Compliance Manager to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.
		Inspected a patch ticket to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.
CTL-069	A DMZ is implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	Inquired of the Senior Security and Compliance Manager to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
		Inspected the firewall rules to verify that a DMZ was implemented to limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
System Operations			
CC7.1 To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.			
CTL-043	Patch management software is utilized to monitor current patch levels of servers.	Inquired of the Senior Security and Compliance Manager to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.

Downloaded as Trial. Apr 2025 15:56:03 GMT
Downloaded by esaadeldin@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected a patch ticket to verify that patch management software was utilized to monitor current patch levels of servers.	No exceptions noted.
CTL-055	Weekly, vulnerability scans are performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope.	Inquired of the Senior Security and Compliance Manager to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.
		Inspected the vulnerability scan configuration and an example of a scan to verify that vulnerability scans were performed to identify weaknesses and vulnerabilities on systems hosting the applications in scope on a weekly basis.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded on 11 Apr 2025 15:56:03 GMT
Downloaded by aaron@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.2 The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.			
CTL-010	The malware software is configured to perform continuous scans and signature updates on servers.	Inquired of the Senior Security and Compliance Manager to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.
		Inspected the antivirus dashboard and antivirus enabled on workstations to verify that the malware software was configured to perform continuous scans and signature updates on servers.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded by [illegible] 2025 15:56:05 GMT
Downloaded by [illegible]@[illegible]controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.3 The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.			
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.

Downloaded on Mar 2, 2025 15:56:03 GMT
Downloaded by asaad@chandeintrdstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-056	Help desk tickets are managed in a ticketing system to monitor status and ensure tickets are reviewed and resolved in a timely manner.	Inquired of the Senior Security and Compliance Manager to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
		Inspected the help desk ticketing system dashboard to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded by E. Ll. on 2025-11-11 15:56:03 GMT
Downloaded by vessa@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.4 The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.			
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-036	Weekly, Executive Management meets to discuss business objectives and establish company direction.	Inquired of the Senior Security and Compliance Manager to verify that Executive Management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
		Inspected the meeting minutes for a sample of weeks during the examination period to verify that executive management met to discuss business objectives and establish company direction on a weekly basis.	No exceptions noted.
CTL-037	Annually, executive meetings are held to establish direction and address operational and IT related issues and risks that may impact service commitments.	Inquired of the Senior Security and Compliance Manager to verify that executive meetings were held on an annual basis to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asaad@chandeintrdstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the organization strategy and logistics meeting minutes to verify that executive meetings were held within the past 12 months to establish direction and address operational and IT related issues and risks that may impact service commitments.	No exceptions noted.
CTL-056	Help desk tickets are managed in a ticketing system to monitor status and ensure tickets are reviewed and resolved in a timely manner.	Inquired of the Senior Security and Compliance Manager to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
		Inspected the help desk ticketing system dashboard to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded by E. Ali on 2025-11-11 15:56:03 GMT
Downloaded by vessa@cloudcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CC7.5 The entity identifies, develops, and implements activities to recover from identified security incidents.			
CTL-005	An assessment of major incidents is performed through root-cause analysis to prevent similar incidents in the future.	Inquired of the Senior Security and Compliance Manager to verify that an assessment of major incidents was performed through analysis after-action reports to prevent similar incidents in the future.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-012	Daily, a backup job scheduler is configured to perform backups of the production system.	Inquired of the Senior Security and Compliance Manager to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis.	No exceptions noted.
		Inspected the backup configurations to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis.	No exceptions noted.
CTL-013	Backups are encrypted and stored separate from where the primary data source resides.	Inquired of the Senior Security and Compliance Manager to verify that backups were encrypted and stored separate from where the primary data source resides.	No exceptions noted.
		Inspected the backup encryption configurations to verify that backups were encrypted and stored separate from where the primary data source resides.	No exceptions noted.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by asad@auditcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-014	The backup system is configured to retain backup data for 14 days.	Inquired of the Senior Security and Compliance Manager to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
		Inspected the backup configuration to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
CTL-056	Help desk tickets are managed in a ticketing system to monitor status and ensure tickets are reviewed and resolved in a timely manner.	Inquired of the Senior Security and Compliance Manager to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
		Inspected the help desk ticketing system dashboard to verify that help desk tickets were managed in a ticketing system to monitor status and ensure tickets were reviewed and resolved in a timely manner.	No exceptions noted.
CTL-067	Quarterly, all-hands meetings are held to discuss operational, IT, and client related topics.	Inquired of the Senior Security and Compliance Manager to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
		Inspected the all-hands meeting slide deck for a sample of quarters during the examination period to verify that all-hands meetings were held on a quarterly basis to discuss operational, IT, and client related topics.	No exceptions noted.
CTL-074	A security incident response program is established to respond, report, escalate and treat breaches and reported security events or incidents.	Inquired of the Senior Security and Compliance Manager to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.
		Inspected the incident response plan to verify that a security incident response program was established to respond, report, escalate and treat breaches and reported security events or incidents.	No exceptions noted.

Downloaded on 11 Apr 2025 15:56:03 GMT
Downloaded by ssadc@auditcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
Change Management			
CC8.1 The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.			
CTL-016	A change management ticketing system is utilized to facilitate the change management process.	Inquired of the Senior Security and Compliance Manager to verify that a change management ticketing system was utilized to facilitate the change management process.	No exceptions noted.
		Inspected the deployment ticket to verify that a change management ticketing system was utilized to facilitate the change management process.	No exceptions noted.
CTL-017	QA testing is performed for application changes prior to deployment to the production environment.	Inquired of the Senior Security and Compliance Manager to verify that QA testing was performed for application changes prior to deployment to the production environment.	No exceptions noted.
		Inspected the QA testing for a recently implemented application change to verify that QA testing was performed for application changes prior to deployment to the production environment.	No exceptions noted.
CTL-018	Application changes are approved by management prior to migration to the production environment.	Inquired of the Senior Security and Compliance Manager to verify that application changes were approved by management prior to migration to the production environment.	No exceptions noted.
		Inspected the approval for a recently implemented application change to verify that application changes were approved by management prior to migration to the production environment.	No exceptions noted.
CTL-019	Access for deploying changes into the production environment is restricted to personnel commensurate with their job role.	Inquired of the Senior Security and Compliance Manager to verify that access for deploying changes into the production environment was restricted to personnel commensurate with their job role.	No exceptions noted.

Downloaded at Fri, 18 Apr 2025 15:56:03 GMT
Downloaded by ocadadelaccontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the deployment user listing to verify that access for deploying changes into the production environment was restricted to personnel commensurate with their job role.	No exceptions noted.
CTL-020	Development and testing environments are logically separate from the production environment.	Inquired of the Senior Security and Compliance Manager to verify that development and testing environments were logically separate from the production environment.	No exceptions noted.
		Inspected the separate logical spaces to verify that development and testing environments were logically separate from the production environment.	No exceptions noted.
CTL-022	A code repository and versioning software is used to track and monitor changes to scripts and source code used to provision, update, or deploy services and applications on production servers.	Inquired of the Senior Security and Compliance Manager to verify that a code repository and versioning software was used to track and monitor changes to scripts and source code used to provision, update, or deploy services and applications on production servers.	No exceptions noted.
		Inspected the code repository tool to verify that a code repository and versioning software was used to track and monitor changes to scripts and source code used to provision, update, or deploy services and applications on production servers.	No exceptions noted.
CTL-046	Change control policies and procedures are documented, maintained, and available to guide personnel through the change control process.	Inquired of the Senior Security and Compliance Manager to verify that change control policies and procedures were documented, maintained, and available to guide personnel through the change control process.	No exceptions noted.
		Inspected the Operations Security Policy and the Secure Development Policy to verify that change control policies and procedures were documented, maintained, and available to guide personnel through the change control process.	No exceptions noted.

Downloaded at 01:11 AM 2025-15-56:03 GMT
Downloaded by aaaa

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
Risk Mitigation			
CC9.1 The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.			
CTL-003	Annually, a risk assessment is performed by management and includes identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	Inquired of the Senior Security and Compliance Manager to verify that a risk assessment was performed by management on an annual basis and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
		Inspected the risk assessment and risk registry in Vanta to verify that a risk assessment was performed by management within the past 12 months and included identifying and assessing the risks associated with identified threats that may impair service commitments and system requirements.	No exceptions noted.
CTL-004	Incident response procedures are maintained and available to guide personnel when responding to security incidents and breaches.	Inquired of the Senior Security and Compliance Manager to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
		Inspected the incident response plan to verify that incident response procedures were maintained and available to guide personnel when responding to security incidents and breaches.	No exceptions noted.
CTL-006	A system is in place to monitor and track security events from identification to resolution.	Inquired of the Senior Security and Compliance Manager to verify that a system was in place to monitor and track security events from identification to resolution.	No exceptions noted.
		Inspected the event ticket logs to verify that a system was in place to monitor and track security events from identification to resolution.	No exceptions noted.

Downloaded on Jul 13, 2026 at 15:56:03 GMT
Downloaded by ashish@bdcontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-008	Annually, the DR plan is tested and updated.	Inquired of the Senior Security and Compliance Manager to verify that the DR plan was tested and updated on an annual basis.	No exceptions noted.
		Inspected the DR test exercise and post meeting notes to verify that the DR plan was tested and updated within past 12 months.	No exceptions noted.
CTL-042	A cyber insurance policy is maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	Inquired of the Senior Security and Compliance Manager to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	No exceptions noted.
		Inspected the cyber insurance policy to verify that a cyber insurance policy was maintained to offset the financial impact incurred by the company in the event of a security incident or data breach.	No exceptions noted.
CC9.2 The entity assesses and manages risks associated with vendors and business partners.			
CTL-053	A vendor management policy is documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	Inquired of the Senior Security and Compliance Manager to verify that a vendor management policy was documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	No exceptions noted.

Downloaded at 11:12 Apr 2025 15:56:03 GMT
Downloaded by asad@securitycontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the Third-Party Management Policy to verify that a vendor management policy was documented and made available to personnel to define the requirements necessary for the onboarding and monitoring of vendors.	No exceptions noted.
CTL-057	SLAs are in place with the managed services providers that support the critical components within the production environment.	Inquired of the Senior Security and Compliance Manager to verify that SLAs were in place with the managed services providers that support the critical components within the production environment.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-058	An inventory of vendors is maintained to track the status of active service providers that are employed by the organization.	Inquired of the Senior Security and Compliance Manager to verify that that an inventory of vendors was maintained to track the status of active service providers that were employed by the organization.	No exceptions noted.
		Inspected the vendor inventory to verify that that an inventory of vendors was maintained to track the status of active service providers that were employed by the organization.	No exceptions noted.
CTL-059	As part of the onboarding process, NDAs are executed with vendors that define the responsibilities and scope of services provided.	Inquired of the Senior Security and Compliance Manager to verify that as part of the onboarding process, agreements were executed with vendors that define the responsibilities and scope of services provided.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.

Downloaded at Fri, 19 Apr 2024 15:56:03 GMT
Downloaded by asad@uniacontrolstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
CTL-061	Due diligence is performed during the vendor onboarding process to determine if they can meet organizational standards and obligations once under contract.	Inquired of the Senior Security and Compliance Manager to verify that due diligence was performed during the vendor onboarding process to determine if they could meet organizational standards and obligations once under contract.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-072	BAAs are executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that BAAs were executed with vendors, as needed, that define the responsibility of each party as it relates to security / availability / confidentiality of data as a component of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-073	Agreements are executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	Inquired of the Senior Security and Compliance Manager to verify that contract agreements were executed with vendors with access to sensitive data that define the responsibility of each party as it relates to the security / availability / confidentiality of data as part of the onboarding process.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by vessa@studiocontrolstudio.com

Availability Category and Criteria

Information and systems are available for operation and use to meet the entity's objectives.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
A1.1 The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.			
CTL-023	Executed agreements are maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	Inquired of the IT Security Team to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
		Inspected the executed agreement for a sample of onboarded clients during the examination period to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
CTL-071	Enterprise monitoring systems are configured to send alert notifications to IT personnel when predefined thresholds are exceeded.	Inquired of the Senior Security and Compliance Manager to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
		Inspected the monitoring system, alert rules, and notification configurations to verify that enterprise monitoring systems were configured to send alert notifications to IT personnel when predefined thresholds were exceeded.	No exceptions noted.
A1.2 The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.			
CTL-007	A DR plan is in place and available to guide personnel in the event of an unexpected disruption in operations.	Inquired of the Senior Security and Compliance Manager to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.

Downloaded on Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by casey.tsai@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the business continuity and disaster recovery plan to verify that a DR plan was in place and available to guide personnel in the event of an unexpected disruption in operations.	No exceptions noted.
CTL-012	Daily, a backup job scheduler is configured to perform backups of the production system.	Inquired of the Senior Security and Compliance Manager to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis.	No exceptions noted.
		Inspected the backup configurations to verify that a backup job scheduler was configured to perform backups of the production system on a daily basis.	No exceptions noted.
CTL-013	Backups are encrypted and stored separate from where the primary data source resides.	Inquired of the Senior Security and Compliance Manager to verify that backups were encrypted and stored separate from where the primary data source resides.	No exceptions noted.
		Inspected the backup encryption configurations to verify that backups were encrypted and stored separate from where the primary data source resides.	No exceptions noted.
CTL-014	The backup system is configured to retain backup data for 14 days.	Inquired of the Senior Security and Compliance Manager to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
		Inspected the backup configuration to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
CTL-045	Backup policies and procedures are documented and available to guide personnel in the backup process.	Inquired of the Senior Security and Compliance Manager to verify that backup policies and procedures were documented and available to guide personnel in the backup process.	No exceptions noted.
		Inspected the Operations Security Policy to verify that backup policies and procedures were documented and available to guide personnel in the backup process.	No exceptions noted.

Downloaded at 11:11 AM 20-05-15:56:03 GMT
Downloaded by asad@cdcindustrialstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
A1.3 The entity tests recovery plan procedures supporting system recovery to meet its objectives.			
CTL-008	Annually, the DR plan is tested and updated.	Inquired of the Senior Security and Compliance Manager to verify that the DR plan was tested and updated on an annual basis.	No exceptions noted.
		Inspected the DR test exercise and post meeting notes to verify that the DR plan was tested and updated within past 12 months.	No exceptions noted.
CTL-014	The backup system is configured to retain backup data for 14 days.	Inquired of the Senior Security and Compliance Manager to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
		Inspected the backup configuration to verify that the backup system was configured to retain backup data for 14 days.	No exceptions noted.
CTL-015	Annually, restoration testing is completed to ensure integrity of backup data.	Inquired of the Senior Security and Compliance Manager to verify that restoration testing was completed to ensure integrity of backup data on an annual basis.	No exceptions noted.
		Inspected the restoration test meeting invite and the post meeting notes to verify that restoration testing was done during a virtual walkthrough meeting within the past 12 months.	No exceptions noted.

Downloaded at Fri, 11 Apr 2025 15:56:03 GMT
Downloaded by aaad@cloudcontrolstudio.com

Confidentiality Category and Criteria

Information designated as confidential is protected to meet the entity's objectives.

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
C1.1 The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.			
CTL-023	Executed agreements are maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	Inquired of the IT Security Team to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
		Inspected the executed agreement for a sample of onboarded clients during the examination period to verify that executed agreements were maintained with clients to communicate service levels and the responsibilities of each party as they pertain to security, availability, and confidentiality of data.	No exceptions noted.
CTL-028	Upon hire, employees are required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	Inquired of the Senior Security and Compliance Manager to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Inspected the executed confidentiality acknowledgement for a sample of new hires during the examination period to verify that upon hire, employees were required to sign a confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
CTL-052	A defined risk methodology is in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	Inquired of the Technical Staff to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	No exceptions noted.

Downloaded at Fri, 12 Apr 2024 15:56:03 GMT
Downloaded by ashish@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
		Inspected the Risk Management Policy to verify that a defined risk methodology was in place to ensure that standards exist for the treatment of risks throughout the environment to an acceptable level.	No exceptions noted.
CTL-057	SLAs are in place with the managed services providers that support the critical components within the production environment.	Inquired of the Senior Security and Compliance Manager to verify that SLAs were in place with the managed services providers that support the critical components within the production environment.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-059	As part of the onboarding process, NDAs are executed with vendors that define the responsibilities and scope of services provided.	Inquired of the Senior Security and Compliance Manager to verify that as part of the onboarding process, agreements were executed with vendors that define the responsibilities and scope of services provided.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-060	Annually, management obtains and reviews the sub-service organization's Service Auditor's reports to verify that controls are in place and operating effectively to safeguard their data.	Inquired of the Technical Staff to verify that management obtained and reviewed the sub-service organization's Service Auditor's report on an annual basis to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.
		Inspected the sub-service organization's report to verify that management obtained and reviewed the sub-service organization's service auditor's reports within the past 12 months to verify that controls were in place and operating effectively to safeguard their data.	No exceptions noted.

Downloaded at 11:11 AM 2025 15:56:03 GMT
Downloaded by asadeel@controlstudio.com

#	Control Activities Specified by the Service Organization	Tests Applied by the Service Auditor	Testing Results
CTL-076	The organization's privacy policy is made available to external parties via the company website.	Inquired of the Senior Security and Compliance Manager to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.
		Inspected the Privacy Policy on the company website to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.
C1.2 The entity disposes of confidential information to meet the entity's objectives related to confidentiality.			
CTL-035	A Destruction Declaration is retained as evidence of the destruction of information assets.	Inquired of the Senior Security and Compliance Manager to verify that a Destruction Declaration was retained as evidence of the destruction of information assets.	No exceptions noted.
		No tests of the control were performed because the circumstances that warranted the operation of the control did not occur during the examination period.	N/A
CTL-048	Policies and procedures for the retention and destruction of information assets are maintained and available to guide personnel.	Inquired of the Senior Security and Compliance Manager to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
		Inspected the Data Management Policy to verify that policies and procedures for the retention and destruction of information assets were maintained and available to guide personnel.	No exceptions noted.
CTL-076	The organization's privacy policy is made available to external parties via the company website.	Inquired of the Senior Security and Compliance Manager to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.
		Inspected the Privacy Policy on the company website to verify that the organization's privacy policy was made available to external parties via the company website.	No exceptions noted.

Downloaded at 11:11 Apr 02 2025 15:56:03 GMT
Downloaded by asad@complianceontrolstudio.com